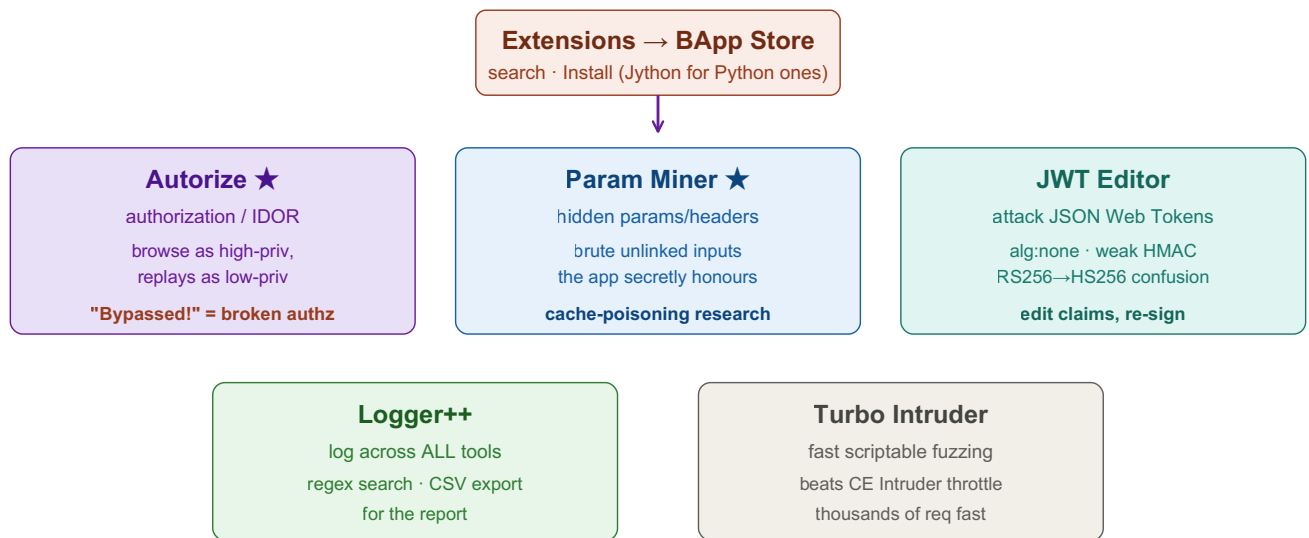


Burp Extensions

BApp Store extensions that add specialised capability to Burp. The two that change your testing the most: Authorize (broken-access-control across the whole app) and Param Miner (hidden inputs). All shown work in Community Edition. Replace <placeholders> with your own values.



Load only what you need — each extension adds memory + passive checks.

① Install Extensions

Tab 1 · Burp

Extensions tab → BApp Store → search → Install

Python extensions need Jython: Extensions → Extensions settings → Python environment → point to jython-standalone.jar. If an entry is greyed out, that's usually why.

② Authorize — Authorization / IDOR ★ must-have

Replays every request you make as a low-priv user automatically, flagging broken access control across the whole app.

Tab 2 · Authorize

1. Log in as the HIGH-priv user in Burp's browser.
2. Authorize tab → "Configure" → paste the LOW-priv user's Cookie / Authorization header.
3. Toggle "Authorize is off" → ON.
4. Browse the app normally as the high-priv user.

*Results: **Bypassed!** = low-priv user got the same data (IDOR / broken authz) · **Enforced!** = blocked · **Is enforced???** = check by hand. Catches horizontal + vertical privilege bugs at once.*

③ Param Miner — Hidden Inputs ★

Brute-forces unlinked parameters/headers the app still processes.

Tab 3 · Param Miner

right-click request → Extensions → Param Miner → "Guess parameters"
("Guess headers" / "Guess cookies")

Finds hidden debug params and unkeyed inputs for web-cache-poisoning research. Output appears in Issues / the extension's tab.

④ JWT Editor — Token Attacks

Adds a "JSON Web Token" tab in Repeater to tamper and re-sign JWTs.

Tab 4 · JWT Editor

- alg:none strip the signature
- weak HMAC secret crack offline → re-sign
- key confusion RS256 → HS256 using the public key as the HMAC secret
- jwk / kid injection

edit claims (e.g. "role":"admin") → re-sign → resend

⑤ Logger++ & Turbo Intruder + others

Tab 1 · More

Logger++	filterable log across ALL Burp tools; regex search; CSV export
Turbo Intruder	fast, scriptable sending – the CE answer to throttled Intruder
Active Scan++	extra scanner checks (Pro)
Hackvertor	inline tag-based encoding/encryption in requests
interactsh / Collaborator Everywhere	out-of-band (OOB) hit detection
Content Type Converter	flip JSON↔XML↔form to surface parser bugs

Turbo Intruder loads a Python template + requests-per-second setting — run thousands of requests fast without CE's Intruder throttle.

Key idea: stock Burp covers the core loop; extensions cover the specialised work. The two that change your testing the most are Authorize (finds broken access control across the entire app automatically while you just browse) and Param Miner (reveals inputs the app never advertised). JWT Editor, Logger++, and Turbo Intruder round out tokens, logging, and fast fuzzing.